

项目	详情
漏洞模块	ngx_http_rewrite_module（URL 重写模块）
漏洞类型	堆缓冲区溢出
严重程度	中（官方评级），但在特定条件下可实现远程代码执行
影响版本	Nginx 开源版 0.6.27 ~ 1.30.0
不受影响版本	1.30.1+、1.31.0+
漏洞成因	rewrite 脚本引擎的两阶段处理存在状态不一致，当配置满足特定条件（如 rewrite 指令后跟随 rewrite/if/set 指令，且使用未命名的 PCRE 正则表达式）时，可触发堆缓冲区溢出
利用条件	未授权攻击者发送特制 HTTP 请求即可触发；在关闭 ASLR（地址空间随机化）的系统中，可进一步实现远程代码执行
补充说明	这个漏洞隐藏了近 18 年，源于 rewrite 模块早期的设计缺陷，在复杂配置场景下才会触发。虽然官方评级为“中危”，但在攻击者控制的特制配置或低安全环境中，存在远程代码执行的高风险，建议所有受影响版本的用户尽快处理。
修复办法	升级 Nginx 版本（最根本的解决方式） 直接升级到官方修复版本：1.30.1+ 或 1.31.0+，这是唯一能彻底消除漏洞的方法。 临时配置缓解措施（无法升级时使用） 检查并简化 nginx.conf 中 rewrite 相关配置，避免使用多层嵌套的 rewrite/if/set 组合指令 优先使用命名正则表达式，避免在 rewrite 中使用复杂的未命名 PCRE 正则 开启系统的 ASLR（大部分现代 Linux 系统默认开启），降低漏洞被利用执行代码的风险 防护加固建议 限制 Nginx Worker 进程权限，避免以 root 用户运行 配置 WAF（Web 应用防火墙），拦截可疑的特制 HTTP 请求 定期更新系统和依赖组件，保持环境安全